CRA Stewardship

OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Agenda

- Introduction
- CRA Stewards Obligations
- Beyond Legal Obligations
- Next steps

Introduction

CRA Stewards one-pager and playbook

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

OpenSSF Global Cyber Policy Working Group

OSS Stewards Obligations Checklist

This is a checklist of the requirements Open Source Stewards must fulfill to meet the requirements laid out in the CRA

An Open Source Steward is defined in Article 3.14 as:

> *a legal person, other than a manufacturer, that has the purpose or objective of systematically providing support on a sustained basis for the development of specific products with digital elements, qualifying as free and open-source software and intended for commercial activities, and that ensures the viability of those products*

Check	Area	Citation	Requirement	TI/DR
			1. Open-source software stewards shall put in place and document in a verifiable manner a cybersecurity policy to foster the development	

LF CRA Stewards ED/GM One Pager

OpenSSF

Create CRA Steward One-Pager outlining obligations

Added a comprehensive one-pager outlining the obligations of Linux Foundation CRA Stewards under the EU Cyber Resilience Act (CRA). This document includes a summary of key responsibilities, a detailed list of actions to take, and references to relevant policies and resources.

Signed-off-by: CRob <69357996+SecurityCRob@users.noreply.github.com>

SecurityCRob authored on Nov 18, 2025 · 1 / 1 · Verified

Prev Next Browse files

commit f9e0d5f

documents/CRA/CRA_Steward_One_Pager.md +40

Linux Foundation CRA Stewards "One-Pager"

TL/DR

In plain language, here is what the Steward's obligations come down to:

1. Provide a vulnerability reporting process and a cybersecurity policy, to be adopted and publicly shared by each affected project, including details on secure development practices.
2. Have a single point of contact for reporting and inquiring about vulnerabilities and potential incidents - both for the repo code and infrastructure (e.g. https://www.linuxfoundation.org/security)
3. If approached by EU officials (Market Surveillance Authority (MSA), ENISA, National CSIRT, etc.) provide requested information as able. If unsure consult with our security SMEs.
4. If a project's software is known to be actively exploited or if foundation infrastructure has suffered a cybersecurity incident, report to the ENISA Single Reporting Platform (SRP).

LF CRA Playbook

OpenSSF

Congratulations! You get to be an open source Steward as outlined within the EU's Cyber Resilience Act (CRA). You are vitally important in supporting upstream projects, developers, and maintainers as they go about the task of maintaining and creating innovative solutions that solve the world's problems. The Steward role was recognized early on by EU policymakers as distinct from the software creators and the commercial organizations that sell products using those technologies.

- https://github.com/ossf/wg-globalcyberpolicy/pull/77/changes/f9e0d5fde3b86e0c9dfc0e3a4936734f34d589cc
- https://docs.google.com/document/d/1xVx7V1sHolYsztLYSMEb_HAAgw9FjBraJDwW7tz3i-k/edit?tab=t.0
- https://docs.google.com/document/d/1DhI-MgWh_8ocoWqNf0PvaIrDzL_1-cdOwrHPUC8THp0/edit?tab=t.0
- https://policy.openssf.org/CRA/checklists/OSS_Stewards_Obligations_Checklist.html

Legal text

The CRA created a new role, the Open Source Steward to help support upstream projects, maintainers and contributors but also the downstream projects and the manufacturers:

*"An '**open-source software steward**' means a legal person, other than a manufacturer, that has the purpose or objective of systematically providing support on a sustained basis for the development of specific products with digital elements (PDEs), qualifying as free and open-source software and intended for commercial activities, and that ensures the viability of those products "*

Article 3.14

Taking into account the importance for cybersecurity of many products with digital elements qualifying as free and open-source software that are published, but not made available on the market within the meaning of this Regulation, legal persons who **provide support on a sustained basis** for the development of such products which are intended for commercial activities, and who **play a main role in ensuring the viability of those products (open-source software stewards), should be subject to a light-touch and tailor-made regulatory regime**. Open-source software stewards include certain foundations as well as entities that develop and publish free and open-source software in a business context, including not-for-profit entities. The regulatory regime should take account of their specific nature and compatibility with the type of obligations imposed. It should only **cover products with digital elements qualifying as free and open-source software that are ultimately intended for commercial activities, such as for integration into commercial services or into monetised products with digital elements**. For the purposes of that regulatory regime, an intention for integration into monetised products with digital elements includes cases where manufacturers that integrate a component into their own products with digital elements either contribute to the development of that component in a regular manner or provide regular financial assistance to ensure the continuity of a software product. **The provision of sustained support to the development of a product with digital elements includes but is not limited to the hosting and managing of software development collaboration platforms, the hosting of source code or software, the governing or managing of products with digital elements qualifying as free and open-source software as well as the steering of the development of such products.** Given that the light-touch and tailor-made regulatory regime does not subject those acting as open-source software stewards to the same obligations as those acting as manufacturers under this Regulation, **they should not be permitted to affix the CE marking** to the products with digital elements whose development they support.

Recital 19

Legal text

Obligations of open-source software stewards

1. Open-source software stewards shall put in place and document in a verifiable manner a cybersecurity policy to foster the development of a secure product with digital elements as well as an effective handling of vulnerabilities by the developers of that product. That policy shall also foster the voluntary reporting of vulnerabilities as laid down in Article 15 by the developers of that product and take into account the specific nature of the open-source software steward and the legal and organisational arrangements to which it is subject. That policy shall, in particular, include aspects related to documenting, addressing and remediating vulnerabilities and promote the sharing of information concerning discovered vulnerabilities within the open-source community.

2. Open-source software stewards shall cooperate with the market surveillance authorities, at their request, with a view to mitigating the cybersecurity risks posed by a product with digital elements qualifying as free and open-source software.

Further to a reasoned request from a market surveillance authority, open-source software stewards shall provide that authority, in a language which can be easily understood by that authority, with the documentation referred to in paragraph 1, in paper or electronic form.

3. The obligations laid down in Article 14(1) shall apply to open-source software stewards to the extent that they are involved in the development of the products with digital elements. The obligations laid down in Article 14(3) and (8) shall apply to open-source software stewards to the extent that severe incidents having an impact on the security of products with digital elements affect network and information systems provided by the open-source software stewards for the development of such products.

Article 24

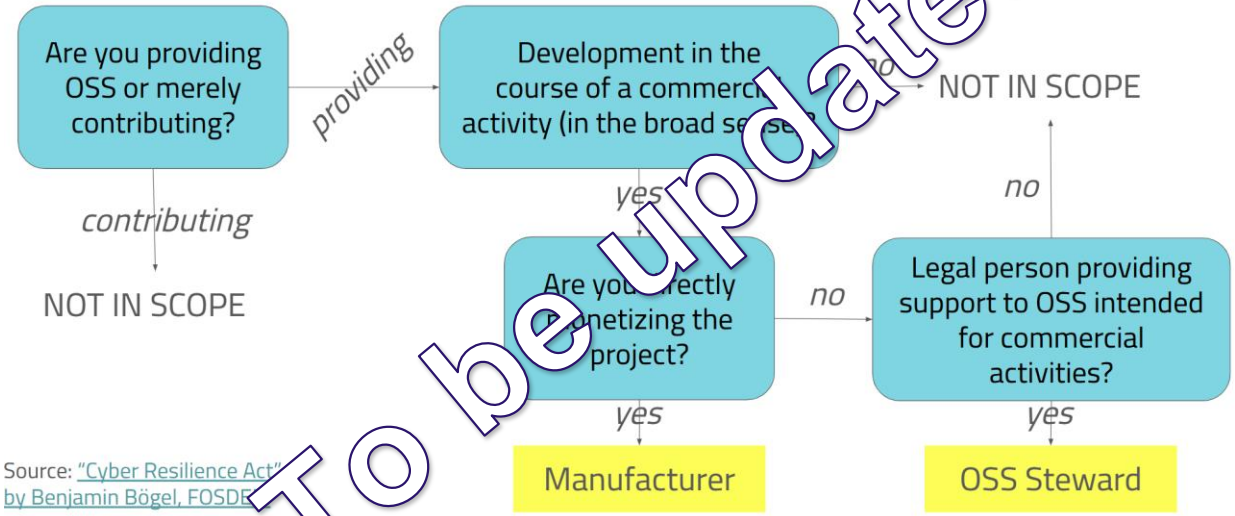
01 Have a vulnerability reporting process and publicly posted policy.

02 Have a single point of contact for reporting and inquiring about vulnerabilities (e.g. https://www.linuxfoundation.org/security)

03 If approached by EU officials (MSA, ENISA, National CSIRT, etc.) provide requested information.

04 If a project is known to be actively exploited or if underlying Foundation infrastructure has suffered a cybersecurity incident, report to the ENISA SRP

Am I a Manufacturer or a Steward?



Source: "Cyber Resilience Act" by Benjamin Bögel, FOSDE

To be updated

Being a steward for one specific product does not mean that that legal entity is to be a steward for other software that it publishes.

A legal entity can be steward for one specific FOSS and a manufacturer for another specific FOSS

A legal entity that publishes a free version and a monetized version of the same FOSS, can be steward for the free one and manufacturer for the second one

CRA Stewards Obligations

Cybersecurity policy

- The scope of the policy (what projects, organizations, or artifacts that are covered by the Policy)
- A valid contact to which to report discovered bugs, defects, and security vulnerabilities.
  - Having a private vulnerability reporting mechanism is a preferred way
- Response time expectations
- Projects' bug bar/review criteria
- Support lifecycle for the project
- Additional project security resources or channels available
- Typically, security.md or security.txt file at the top-level of a project's source code repository

Guide to implementing a coordinated vulnerability disclosure process for open source projects

Table of Contents

- Before you begin
  - About this guide
  - Who's a vulnerability reporter?
  - What does the vulnerability reporter want?
- Set up the vulnerability management *infrastructure*
- Create a vulnerability management team (VMT)
  - Set up report intake
  - Enable private patch development
  - Establish a CNA contact
  - Create an embargo list
  - Select communication templates
- Publish your vulnerability management process
- Apply the vulnerability response process
  - Runbook
  - Response process
- Troubleshooting common challenges to Coordinated Vulnerability Disclosure
- Acknowledgements

oss-vulnerability-guide / templates / security_policies /

ran-dall Fix Markdown

This branch is 156 commits ahead of `google/oss-vulnerability-guide:main`.

Name
..
email_intake.md
github_security_policy.md
other_intake_systems.md

Cooperation with authorities

MSA – Market Surveillance Authorities

- Each EU state will have the obligation to designate an authority (existing or a newly-created one) to fulfill this role

ENISA - European Union Agency for Cybersecurity

- Set up and manage the EU SRP
- It will build the European Cybersecurity Certification framework

CSIRT - Security Incident Response Centres

- Known internationally as CERTs
- Composed of incident response teams appointed by the EU institutions and Member States

ADCO - Administrative Cooperation Group

- European cooperation on market surveillance takes place through informal groups of market surveillance authorities
- A new AdCo for CRA will be created

Search results (4)

DIRECTIVE / REGULATION 2024/2847/EU - Cyber Resilience Act (CRA) Regulation ⊗

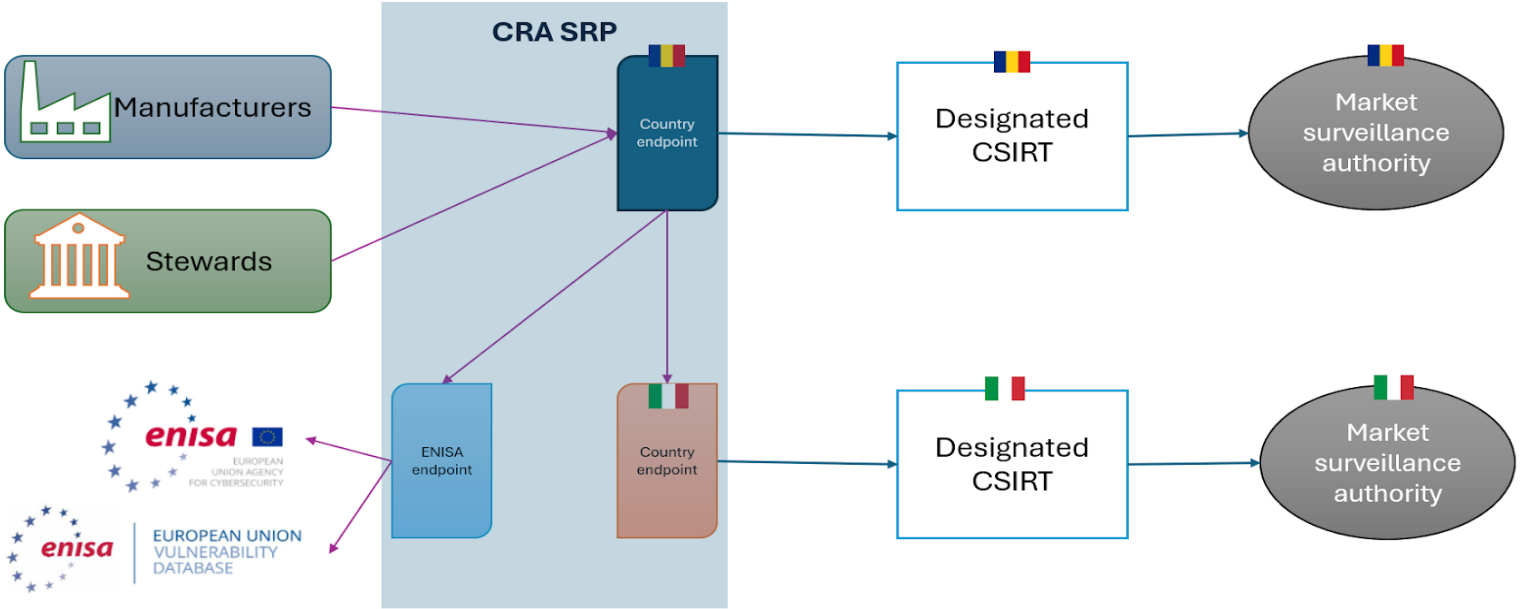
Authority	Street	Postal code	City
National Security Authority	Budatínska	85106	Bratislava
Bundesamt für Sicherheit in der Informationstechnik (BSI)	Godesberger Allee	53175	Bonn
Consumer Rights Protection Centre of Latvia	Brivibas street	LV-1010	Riga
Digital Security Authority	Andrea Chaliou	2408	Nicosia

enisa
European Network and Information Security Agency

https://webgate.ec.europa.eu/single-market-compliance-space/market-surveillance/ma-authorities?filter=legislationId:9021
https://www.enisa.europa.eu/
https://csirtsnetwork.eu/homepage
https://single-market-economy.ec.europa.eu/single-market/goods/building-blocks/market-surveillance/organisation/adcos_en

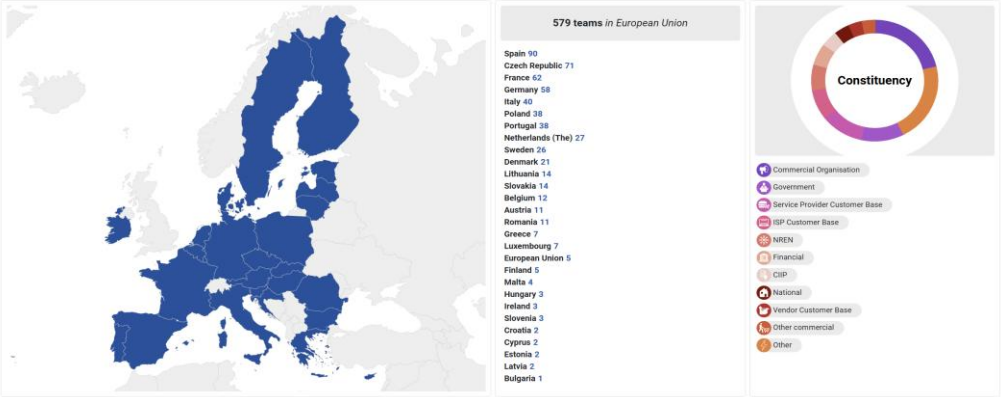
EU SRP

- Article 16



CSIRTs

- How to choose your designated CSIRT
  - Art 14.7
  - The country where it has the main establishment
  - Highest numbers of employees in the Union
  - Authorized representative
  - Highest number of ‘users’
- Delay the dissemination of the notification to the CSIRTs of other Member States - The Delegated Regulation C(2025)8407
  - in the light of an evaluation of the nature of the notified information;
  - if the CSIRT receiving the notification is unable to ensure the confidentiality of such information;
  - if the single reporting platform has been compromised or is temporarily not operational



Reporting obligations

Reporting Obligations

AEV

- Applies to the extent stewards are involved in product development

Incidents

- Applies only if the incident affects the steward's own network/information system used for product development

Steward activity	Applicable CRA article	Reporting obligation
Actively involved in development of a product with digital elements	Art. 24.3 + Art. 14(1)	Report actively exploited vulnerabilities affecting that product
Operating infrastructure used to develop OSS (CI, repos, build systems)	Art. 24.3 + Art. 14(3), (8)	Report severe incidents affecting steward-operated infrastructure.
Passive hosting or mirroring only	None	No CRA reporting obligation
Downstream proprietary product affected by OSS vulnerability	Indirect	Disclosure encouraged, not mandated

OSS stewards should:

- establish internal procedures to ensure timely identification, triage, and escalation of vulnerabilities and incidents that may trigger CRA reporting obligations
- retain records demonstrating compliance with CRA reporting obligations

Article 24.3: *The obligations laid down in Article 14(1) shall apply to open source software stewards to the extent that they are involved in the development of the products with digital elements. The obligations laid down in Article 14(3) and (8) shall apply to open source software stewards to the extent that severe incidents having an impact on the security of products with digital elements affect network and information systems provided by the open source software stewards for the development of such products.*

Article 14.1: *A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.*

Article 14.3: *A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16.*

Article 14.8: *After becoming aware of an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements, the manufacturer shall inform the impacted users of the product with digital elements, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable. Where the manufacturer fails to inform the users of the product with digital elements in a timely manner, the notified CSIRTs designated as coordinators may provide such information to the users when considered to be proportionate and necessary for preventing or mitigating the impact of that vulnerability or incident.*

A vulnerability report should include:

In accordance with the ENISA and CSIRTs Network, a vulnerability report should include at least the next information, when available:

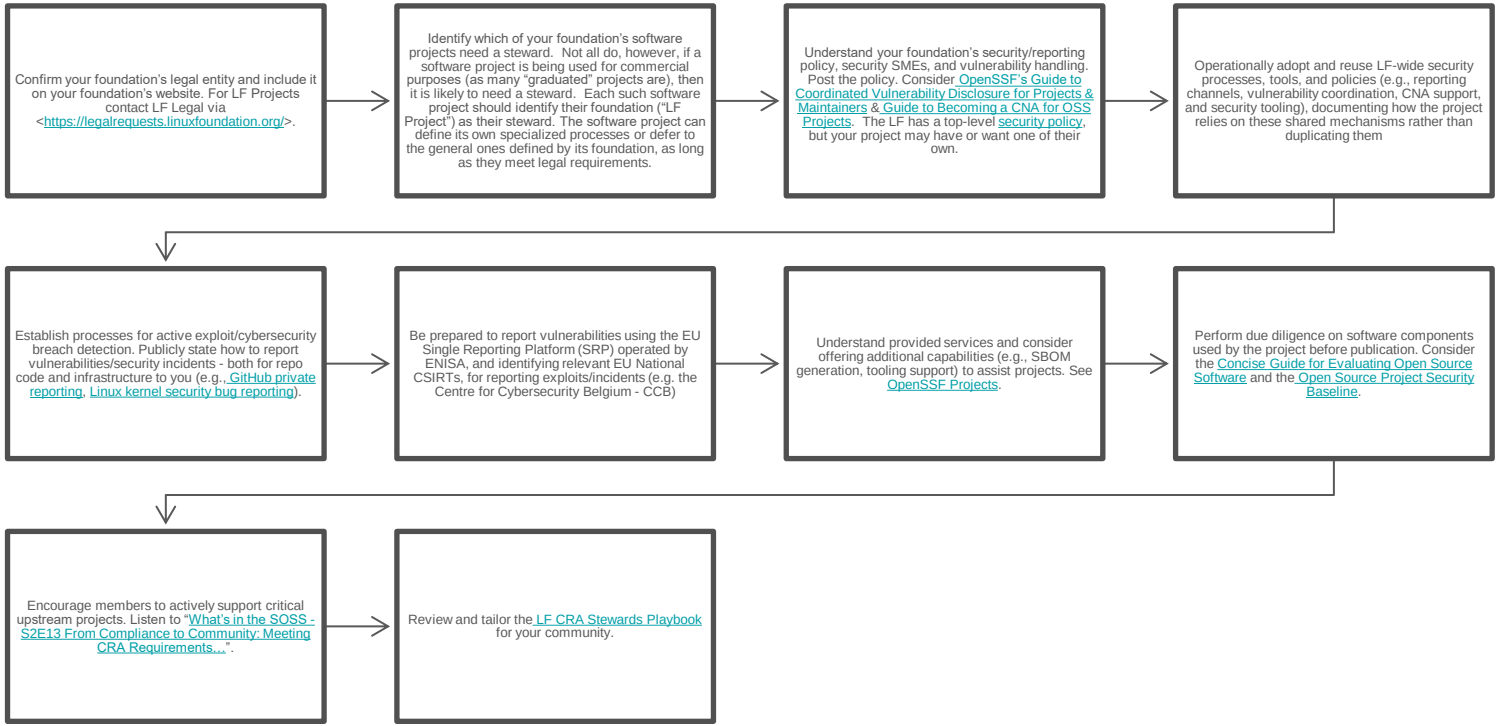
- *"Asset or control where the vulnerability is found (web page, IP address, product or service name)*
- *The version of the product on which the vulnerability is present, or the specific configuration of the product that is vulnerable*
- *Discovered weakness (such as a CWE)*
- *The severity of the vulnerability (e.g., using CVSS to calculate)*
- *A detailed description of the vulnerability, including the following information:*
  - *A summary of the vulnerability*
  - *Required steps to reproduce the vulnerability*
  - *Required configuration to reproduce the vulnerability*
  - *Possible mitigation measures for the vulnerability*
- *Potential impact of the vulnerability*
- *Whether the vulnerability has already been reported to the product manufacturer*
- *Whether a request for a CVE number has been made*
- *Contact information, including secure communication options (PGP fingerprint, etc.)*
- *Any other important information related to the discovered vulnerability"*

https://csirtsnetwork.eu/homepage?tab=cvd

Eventual Requested Information by Authorities

CRA Article	Applicable to OSS Steward?	Requestable Evidence	Non-Requestable Evidence	Notes / Guidance
Art. 14(1) – Reporting actively exploited vulnerabilities	Yes, if actively involved in product development	Notifications submitted to CSIRT and ENISA Timestamped internal logs of vulnerability reports Classification/triage records	Downstream proprietary product assessments SBOMs of products using OSS Risk assessments of unrelated systems	Only applies to vulnerabilities actively exploited in products OSS steward develops.
Art. 14(3) – Reporting severe incidents	Yes, if steward operates network/infrastructure used for product development	Incident reports affecting steward-operated systems Logs or evidence showing assessment of severity Notifications to CSIRT and ENISA	Incidents outside steward infrastructure Product technical documentation unrelated to steward systems	Scope is incidents impacting steward-operated infrastructure.
Art. 14(7) – CSIRT coordination	Indirect	Records showing CSIRT designated as coordinator was notified	Full CSIRT internal communications	Only relevant to show notification compliance; internal CSIRT workflow not required.
Art. 14(8) – User notification	Yes, if a reportable vulnerability or incident occurred	Public advisories, mailing list posts, SECURITY.md or security.txt references Evidence of timing of notification Mitigation instructions provided to users	Proprietary downstream vendor communications Private contributor data	Authorities may check that users were timely informed, not the steward's private communications.
Art. 16 – Single Reporting Platform	Yes, as mandatory under Art. 14(1)/(3)	Proof of submission to the single reporting platform Acknowledgment of receipt by CSIRT/ENISA	Internal technical development files Code reviews unrelated to incident	Provides technical proof of CRA compliance for reporting obligations.
Art. 24(1 and 3) – OSS-specific obligations	Yes, always	Evidence of role (steward vs manufacturer) Scope of OSS involvement (active development vs passive hosting) Documented processes for handling vulnerabilities/incidents including its **cybersecurity policy**	CE marking or conformity assessments Annex VII technical documentation Full product risk analysis	Article 24 limits all requests; authorities cannot impose manufacturer duties on OSS stewards.

The top 10 things to consider by the projects within the Linux Foundation to meet their CRA steward obligations

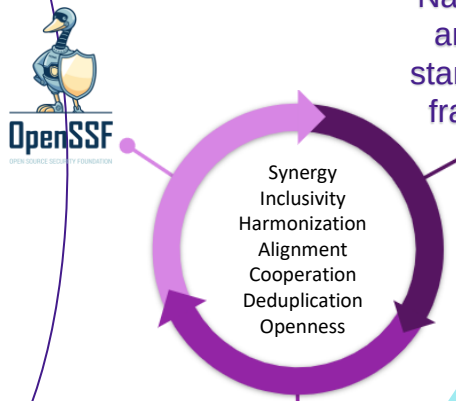


Checklist

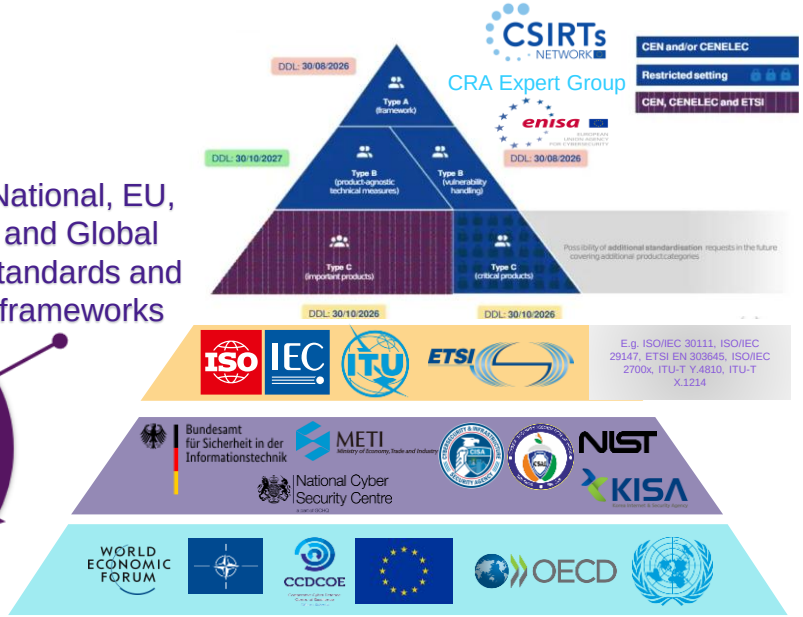
- My Legal Entity Steward is:
- The projects within my scope of stewardship are:
- My Vulnerability and Incident Reporting Policy can be publicly found here:
- If different, my cybersecurity policy can be consulted here:
- My CSIRT is
- A dedicated security contact for vulnerability and incident reports:
- Does the steward provide development infrastructure? If so, is there an incident response plan for these systems?
- Is the steward actively involved in the Product Development? If so, is that reflected in the cybersecurity policy or in another document?

Beyond legal obligations

Beyond legal obligations



National, EU, and Global standards and frameworks



"Building on existing international and European standards"

OSS

Beyond legal obligations

Promote Open Security Standards and Best Practices

- Ensure compliance with EU regulations while remaining globally usable
- Collaborate on global standards

Support threat intelligence and Vulnerability disclosure

- Share threat intelligence and vulnerability data with global security communities and CERTs
- Transparent, standardized security disclosure processes

Collaborate with governments and NGOs

- Create the needed environment to enable global community contributions
- Harmonized regulatory environments that are not blocking open-source innovation

Educate and train

- Provide open, accessible, security education
- Build global capacity

Consulting	Consulting and guidance for open source stewards, maintainers, and manufacturers
Ease compliance process	Streamlining CRA compliance for manufacturers through practical, usable processes, tools and signals
Open source values	Placing open source values - transparency, collaboration, and community - at the core of all compliance activities

Next steps

Next steps

- Solve all the comments from the documents
  - Make both of them publicly available and open for further feedback
  - Continuously improve them based on EC's guidelines and community's feedback
- Start fulfilling our responsibilities
  - Set up a vulnerability reporting process and publicly posted policy.
  - Create a single point of contact for reporting and inquiring about vulnerabilities
  - Establish connections with EU officials (MSA, ENISA, CSIRTs, etc.)
    - Choose our designated CSIRT
    - Engage in the pilot processes for reporting vulnerabilities
- Clarifying the remaining doubts for our mission (e.g. 'sustained support and ensuring viability of FOSS)
- Provide 'consulting services'
- Understand OpenSSF steward approach within The Linux Foundation
- If a project does not have a steward, The Linux Foundation and OpenSSF are happy to accommodate it
  - Guidance
  - Technical clarity
  - Governance and support

Thank You

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Back-up slides

List of referenced obligations in the Article 24

Area	Citation	Requirement	TL/DR
Vuln Reporting	Article 15	Manufacturers as well as other natural or legal persons may notify any vulnerability contained in a product with digital elements as well as cyber threats that could affect the risk profile of a product with digital elements on a voluntary basis to a CSIRT designated as coordinator or ENISA.	*notify ENISA + National CSIRT contact about discovered vulns*
Vuln Reporting	Article 15	Manufacturers as well as other natural or legal persons may notify any incident having an impact on the security of the product with digital elements as well as near misses that could have resulted in such an incident on a voluntary basis to a CSIRT designated as coordinator or ENISA.	*notify ENISA + National CSIRT contact about cyber incidents*
Vuln Reporting	Article 15	The CSIRT designated as coordinator or ENISA shall process the notifications referred to in paragraphs 1 and 2 of this Article in accordance with the procedure laid down in Article 16. The CSIRT designated as coordinator may prioritise the processing of mandatory notifications over voluntary notifications.	*Select a National CSIRT to notify*
Vuln Reporting	Article 15	Where a natural or legal person other than the manufacturer notifies an actively exploited vulnerability or a severe incident having an impact on the security of a product with digital elements in accordance with paragraph 1 or 2, the CSIRT designated as coordinator shall without undue delay inform the manufacturer.	*notify ENISA + National CSIRT contact about active exploited vulns*
Vuln Reporting	Article 15	The CSIRTs designated as coordinators as well as ENISA shall ensure the confidentiality and appropriate protection of the information provided by a notifying natural or legal person. Without prejudice to the prevention, investigation, detection and prosecution of criminal offences, voluntary reporting shall not result in the imposition of any additional obligations upon a notifying natural or legal person to which it would not have been subject had it not submitted the notification.	*CSIRTs may contact Stewards for assistance*
Vuln Reporting	Article 14	A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.	*establish an EU National CSIRT contact, report known actively exploited vulns to EU National CSIRT contact and ENISA*
Vuln Reporting	Article 14	For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit: 1.an early warning notification of an actively exploited vulnerability, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, indicating, where applicable, the Member States on the territory of which the manufacturer is aware that their product with digital elements has been made available; 2.unless the relevant information has already been provided, a vulnerability notification, without undue delay and in any event within 72 hours of the manufacturer becoming aware of the actively exploited vulnerability, which shall provide general information, as available, about the product with digital elements concerned, the general nature of the exploit and of the vulnerability concerned as well as any corrective or mitigating measures taken, and corrective or mitigating measures that users can take, and which shall also indicate, where applicable, how sensitive the manufacturer considers the notified information to be; 3.© unless the relevant information has already been provided, a final report, no later than 14 days after a corrective or mitigating measure is available, including at least the following: 1. a description of the vulnerability, including its severity and impact; 2. where available, information concerning any malicious actor that has exploited or that is exploiting the vulnerability; 3. details about the security update or other corrective measures that have been made available to remedy the vulnerability.	*establish an EU National CSIRT contact, report "severe" vulns to EU National CSIRT contact and ENISA*
Vuln Reporting	Article 14	A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16.	*notify end-consumers of "severe" vulnerabilities*
Vuln Reporting	Article 14	After becoming aware of an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements, the manufacturer shall inform the impacted users of the product with digital elements, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable. Where the manufacturer fails to inform the users of the product with digital elements in a timely manner, the notified CSIRTs designated as coordinators may provide such information to the users when considered to be proportionate and necessary for preventing or mitigating the impact of that vulnerability or incident.	*Notification of impacted users*
Market Surveillance	Article 52	The market surveillance authorities designated under paragraph 2 of this Article shall also be responsible for carrying out market surveillance activities in relation to the obligations for open-source software stewards laid down in Article 24. Where a market surveillance authority finds that an open-source software steward does not comply with the obligations set out in that Article, it shall require the open-source software steward to ensure that all appropriate corrective actions are taken. Open-source software stewards shall ensure that all appropriate corrective action is taken in respect of their obligations under this Regulation.	*Stewards found non-compliant must take corrective actions to respect obligations*

Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.